

Secure AI & Data Governance Control Plane

This document provides a detailed, implementation-focused description of the Secure AI & Data Governance Control Plane for regulated enterprises. The control plane acts as the authoritative policy, routing, and audit layer that intermediates all AI, LLM, RAG, and sensitive data access operations, enforcing organizational and regulatory rules with deterministic, observable behavior.

1. Problem & Vision

Enterprises in regulated sectors are rapidly experimenting with AI and LLMs while operating under strict regulatory, privacy, and security constraints. Current challenges include:

- Inconsistent and opaque use of external and internal models across teams.
- Ad hoc integrations where prompts and data are sent directly to third-party endpoints.
- Limited enforcement of data residency, sensitivity, and purpose limitations.
- Fragmented logging, making it difficult to reconstruct who accessed what through AI workflows.

The Control Plane addresses these by:

- Centralizing policy decisions for AI and data operations.
- Providing a single, inspectable gateway that all AI/RAG/agent calls traverse.
- Making every decision—allow, deny, transform, route—explicit, logged, and auditable.

2. Core Outcomes

The platform is designed to deliver:

- 1) Unified Governance
 - One place to define rules for data, models, and tools instead of scattered controls.
- 2) Safe AI Adoption
 - Teams can innovate with AI using approved paths without violating policy.
- 3) Regulatory Readiness
 - Full traceability of AI-assisted decisions and data usage for audits and regulators.
- 4) Vendor & Model Neutrality
 - Ability to adopt or replace model providers without rewriting governance logic.
- 5) Operational Confidence
 - Deterministic flows and low, predictable latency overhead.

3. Architecture Overview

The Control Plane uses Motia as an execution and orchestration graph for all evaluations, routes, and logging steps.

Key elements:

- Governance Gateway:
 - A FastAPI-based proxy or sidecar that all AI, embedding, RAG, and tool calls pass through.
 - Integrates with enterprise SSO (OIDC/SAML) and service identities.
- Policy Engine (OPA):
 - Rego policies define constraints on datasets, models, tools, regions, and logging.
 - Policies can be unit-tested, staged, and versioned.

- Secrets & Crypto (Vault):
 - Central storage for API keys, certs, encryption keys, with rotation and access policies.
- Data & Tool Connectors:
 - Adapters for vector DBs, knowledge graphs, warehouses, and external tools.
 - Each resource labeled with sensitivity, residency, owner, and permitted uses.
- Observability Stack:
 - Central logging (OpenSearch/SIEM) plus Prometheus/Grafana metrics.
 - Langfuse traces for AI flows where detailed introspection is needed.

4. Key Workflows

4.1 AI Request Evaluation

- Application sends a request (e.g., chat completion, embedding, agent tool call) to the Gateway.
- Gateway authenticates the caller and enriches metadata (user, app, BU, region, labels).
- Motia triggers an evaluation flow:
 - OPA policies are executed to determine allowed models, tools, and datasets.
 - Optional redaction strips sensitive content based on policy.
 - The Model & Tool Router selects the compliant backend.
- The request is executed; response and decisions are logged with correlation IDs.

4.2 RAG & Retrieval Governance

- Before any retrieval, the Control Plane resolves which indexes/collections the caller may use.
- Queries are constrained to allowed scopes; attempts to cross boundaries are denied.
- Retrieved context can be masked before being forwarded to a model provider.

4.3 Model Registry & Provider Governance

- Models are registered with metadata: hosting, jurisdiction, training data constraints, risk tier.
- Policies map which models can be used for:
 - Specific data classes (e.g., no external models for 'restricted' data).
 - Specific geographies (e.g., EU-only workloads).
- This enables controlled experimentation with new models.

4.4 Incident Forensics

- Audit logs support reconstruction of flows:
 - Inputs (appropriately masked), selected models, datasets, policy decisions.
- Enables targeted review and response when issues or suspected misuse arises.

5. Security & Compliance Integration

The Control Plane is built to plug into existing enterprise controls:

- Uses IdP as the source of truth for identity and group membership.
- Streams decision and usage logs into SIEM/SOC pipelines.
- Aligns with data catalogs for dataset classification and ownership.
- Can enforce organization-specific mappings for regulations such as GDPR, HIPAA, PCI-DSS, and sectoral rules.

- Enables clear separation of duties: policy authorship, app development, and operations.

6. Implementation & Extensibility

Phase 1: Introduce the Governance Gateway for a subset of AI/RAG workloads; central logging and basic policies.

Phase 2: Expand coverage to all critical AI services; integrate dataset catalog and stronger redaction controls.

Phase 3: Add fine-grained RAG governance, model registry workflows, and SIEM/SOC automation.

Phase 4: Enable multi-region deployments, PQC enhancements, and automated attestation/reporting packs.

The architecture is vendor-neutral and future-proof: new model providers, tools, or infrastructure components are introduced by registering them and updating policies, not by refactoring each consuming application.